

The Tunnel Is Up — What Actually Happened

Timestamps	File No.	Description
2026-9-2T20:51	E03	Credential attack begins (4 failures), Outside normal hours
20:55	E03	Password accepted
20:55 – 20:56	E04	MFA fatigue attack: 6 pushes, approved on 6th
20:57	E03,7	VPN connection established, Unknown device
20:57	E05	Internal reconnaissance: DNS queries
20:59	E05	Unauthorized finance.internal access
21:00	E05 , 3	~483MB read via SMB , ~487MB transferred to attacker IP

Verdict:
Compromised

Confidence:
Medium

Why not High

*Phase 2
evidence
pending,
credential origin
unknown*

Evidence Assessment

Strongest Evidence:

- E07: Unknown endpoint UNKNOWN-7C91, not Smith's device DEV-JS-441 (offline entire incident)
- E04: 6 MFA pushes in 81 seconds, MFA fatigue attack
- E05: HIGH_VOLUME_READ 483MB via SMB, outside all baseline parameters
- E03: 4 auth failures before success, credential-guessing attack
- E06: Session 2h21m outside normal hours, 5x baseline data volume, finance.internal never accessed in 30 days
- E02 shows curl/8.7.1 user-agent, automated tool, not browser, Smith was asleep

CONTRADICTIONS AND GAPS:

- E02 inner pcap captures only HTTP to 10.66.0.1, does not show SMB, DNS, or finance traffic visible in E05. Likely partial capture, inconsistency noted, not ignored

WHAT WEAKENS THE CASE:

- Cannot fully rule out insider threat without knowing who approved the MFA push
- Credential acquisition method unknown
- E04 device shows "Jordan-iPhone", Smith's phone was involved in approval

Architecture Decision: Hybrid Model

Verdict: Hybrid

Access Scenario	Recommended Model	Reason
Managed remote employees	ZTNA	Device trust + identity verified per session
BYOD / Contractors	ZTNA	No implicit network trust,app level access only
Internal web applications	ZTNA	Proxy-based,no network exposure needed
Legacy non-web services(SMB etc)	VPN(strict)	Cannot be proxied needs network level access but with tight controls
Privileged administrator	ZTNA+PAM	Highest identity assurance,session recording
Emergency/Break-glass	VPN(time-limited)	ZTNA may not be available in outage scenarios

Immediate Response and Long-Term Actions

Immediate

- Revoke j.smith VPN session and credentials immediately
- Force password reset on j.smith account
- Disable push-based MFA , switch to number-matching or TOTP
- Isolate 10.40.20.25 (file server) pending forensic review
- Identify what data was in the 483MB SMB read
- Verify DEV-JS-441 integrity — why was it offline?

Long-term

- Deploy ZTNA for all web-accessible internal applications
- Enforce device compliance check before VPN/ZTNA session establishment
- Implement MFA fatigue protection number matching, context-aware approval
- Block SMB access from VPN unless explicitly required by role
- Alert on: data transfer >2x baseline, access to resources outside role scope, unknown endpoint fingerprints
- Quarterly access reviews, finance.internal should never be reachable by a Software Developer